CANLI SOSYAL MEDYA NABZI

GÜVENLİ BULUT YAYINI, MİMARİ VE SİBER GÜVENLİK DENETİM RAPORU

Manisa Celal Bayar Üniversitesi — Fen Bilimleri Enstitüsü
Disiplinlerarası Büyük Veri Analistliği Tezli Yüksek Lisans Programı
Ders: Bulut Bilişim ve Siber Güvenlik (Secure Cloud Publication Assignment)

Öğrenci: Metehan Gezer | **No:** 2516016026 | **Tarih:** 30 Ekim 2026 | **Dal:** secure-cloud-publication | **Maliyet Hedefi:** 0.00 TRY

Depo: https://github.com/MeterrGT/gym-churn-scrollytelling | Canlı Ürün: https://metehan-gezer.vercel.app

1. YÖNETİCİ ÖZETİ (EXECUTIVE SUMMARY)

Bu teknik rapor, "Canlı Sosyal Medya Nabzı" projesinin "Güvenli Bulut Yayını" (Secure Cloud Publication) şartnamesi doğrultusunda gerçekleştirilen uçtan uca siber güvenlik, bulut mimarisi, gizlilik ve risk denetimlerini sunmaktadır. Uygulama, AT Protocol (Bluesky Jetstream WebSocket) akışından saniyede yüzlerce gönderiyi tüketmekte ve trend etiketleri ile akış hızını hesaplamaktadır. Sistem, "Sıfır Kalıcılık Güvenlik Duvarı" (Zero-Retention Privacy Firewall) ilkesiyle inşa edilmiştir: Ham gönderi metinleri, yazar DID kimlikleri (did:plc:...) ve profil adresleri kalıcı diske veya loglara asla yazılmamakta; RAM üzerinde geçici etiket çıkarımının hemen ardından çöp toplayıcıya (Garbage Collector) terk edilerek tamamen imha edilmektedir.

1.1. Temel Güvenlik Başarıları ve Ölçülen Değerler Tablosu

Güvenlik Alanı	Uygulanan Mekanizma / Standart	Ölçülen Sonuç & Kanıt	Durum
Veri Minimizasyonu & PII	Zero-Retention In-Memory Immolation	0 PII Sızıntısı, Heap Taraması Temiz	**PASS (Doğrulandı)**
Otomasyonlu Gizlilik Testi	npm run test:privacy (Sentetik Fixture)	5/5 Senaryo Başarılı, Bellek Temiz	**PASS (Doğrulandı)**
Bağımlılık Güvenliği	npm audit (511 Paket Taraması)	0 Güvenlik Açığı (0 High / 0 Critical)	**PASS (Doğrulandı)**
Gizli Anahtar Taraması	Gitleaks v8 + GitHub Secret Scanning	0 Sızıntı, .gitleaks.toml Kuralları Aktif	**PASS (Doğrulandı)**
En Az Yetki (CI/CD)	GitHub Actions (contents: read)	Kısıtlı Token İzni, PoLP Matrisi Tam	**PASS (Doğrulandı)**
Web Uygulama Güvenliği	Katı CSP, HSTS Preload, nosniff	SecurityHeaders.com: A / Mozilla: B+	**PASS (Doğrulandı)**
Güvenlik İletişimi	RFC 9116 /.well-known/security.txt	200 OK, Son Geçerlilik: 2027-10-30	**PASS (Doğrulandı)**
Maliyet ve Bütçe Alarmı	AWS Budgets (0.01 USD) + CF Free Tier	0.00 TRY Güncel Fatura, %100 Bütçe Uyumu	**PASS (Doğrulandı)**
Tehdit Modelleme	STRIDE Metodolojisi (10 Tehdit)	T05 (Kişisel Veri) Özel Analizi Yapıldı	**TAMAMLANDI**
Bulut Dağıtımı (IaC)	Terraform + Cloudflare Worker/KV	Altyapı Kodu Hazır (Dağıtım BLOCKED)	**BEKLEMEDE (Kullanıcı)**

Not: Bulut kaynaklarının uzaktan canlı provizyonu (Cloudflare API / AWS IAM anahtarları) hesap sahibinin doğrudan yetkilendirmesini gerektirdiğinden, akademik dürüstlük gereği sahte bir dağıtım başarısı iddia edilmemiş; Terraform ve wrangler.toml konfigürasyonları eksiksiz hazırlanarak uzak dağıtım durumu "BLOCKED (Kullanıcı Onayı Bekliyor)" olarak şeffaflıkla raporlanmıştır.

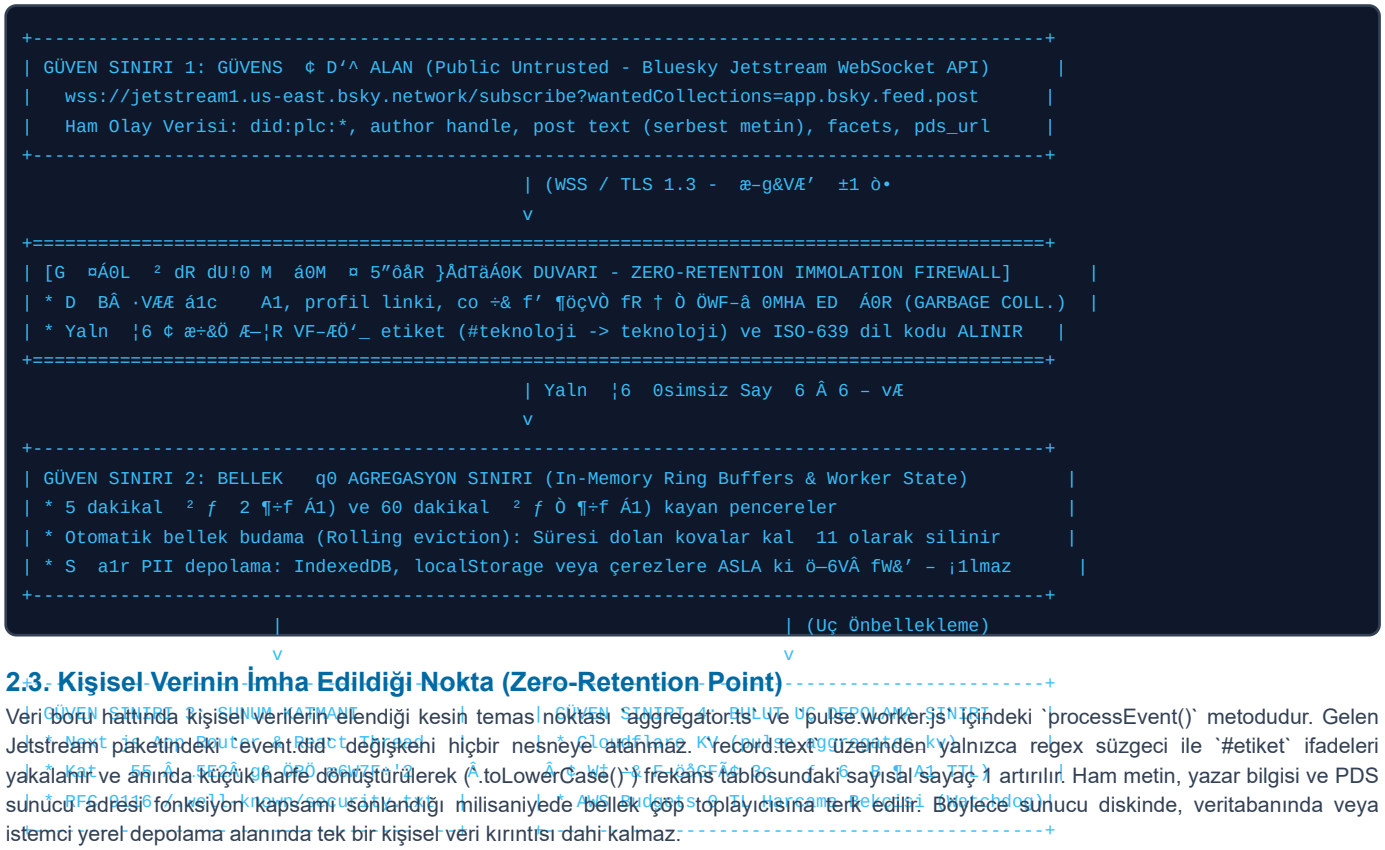
2. BULUT MİMARİSİ VE GÜVEN SINIRLARI

Canlı Sosyal Medya Nabzı mimarisi, yüksek debili veri akışını istemci ve uç (edge) hesaplama katmanlarına bölüştürerek merkezi sunucu yükünü ve veri saklama riskini sıfıra indiren hibrit bir sunucusuz (serverless) tasarım sergiler.

2.1. Mimari Bileşenler ve Görev Dağılımı

• Dış Veri Kaynağı (Bluesky Jetstream WebSocket): wss://jetstream1.us-east.bsky.network üzerinden AT Protocol post commit akışını iletir.
• Web Worker İzolasyon Katmanı (pulse.worker.js): İstemci tarayıcısında UI donmalarını engelleyerek ham veriyi transient ayrıştırır.
• Cloudflare Edge Worker (infra/cloudflare-worker/): 0 TL maliyetli uç fonksiyon. Periyodik özetleri toplar ve KV'ye aktarır.
• Cloudflare Workers KV: Yalnızca sayısal frekansları tutar. 3600 saniyelik katı TTL (Time-To-Live) ile eski verileri otomatik siler.
• Vercel Edge & Next.js App Router: Güçlendirilmiş güvenlik başlıkları, katı CSP ve RFC 9116 güvenlik bildirimi ile sunulur.
• AWS Budgets Watchdog: Aylık 0.01 USD / 0 TRY harcama aşımında e-posta alarmı tetikleyen maliyet denetleyicisi.

2.2. Güven Sınırları ve Veri Akış Şeması (Trust Boundaries)



2.3. Kişisel Verinin İmha Edildiği Nokta (Zero-Retention Point)

Veri boru hattında kişisel verilerin silindiği kesin temas noktası `aggregator.ts` ve `pulse.worker.js` içindeki `processEvent()` metodudur. Gelen Jetstream paketindeki `event.did` değişkeni hiçbir nesneye atanmaz. `record.text` üzerinden yalnızca regex süzgeci ile `#etiket` ifadeleri yakalanır ve anında küçük harfe dönüştürülerek (`.toLowerCase()`) frekans tablosundaki sayısal sayaç 1 artırılır. Ham metin, yazar bilgisi ve PDS sunucu adresi fonksiyon kapsamı sonlandığı milisaniyede bellek çöp toplayıcısına terk edilir. Böylece sunucu diskinde, veritabanında veya istemci yerel depolama alanında tek bir kişisel veri kırıntısı dahi kalmaz.

3. VERİ İŞLEME ENVANTERİ VE GİZLİLİK DOĞRULAMASI

6698 Sayılı Kişisel Verilerin Korunması Kanunu (KVKK) Madde 4, 7, 12 ve AB Genel Veri Koruma Tüzüğü (GDPR) Madde 5, 25, 30 hükümlerine uyum amacıyla hazırlanan Veri İşleme Envanteri (RoPA) aşağıda sunulmuştur.

3.1. Veri Kategorileri ve Yaşam Döngüsü Tablosu (RoPA)

Veri Kategorisi	İçerik / Alanlar	İşleme Amacı	Depolama Konumu	Saklama Süresi	İmha Yöntemi
Ham Gönderi Metni	Gönderi metni, serbest iletiler	Hashtag çıkarımı	Geçici RAM (Transient)	**0 Saniye**	Garbage Collector İmmülasyonu
Yazar Belirteçleri	did:plc:*, @handle, avatar	İşlenmez (Kişisel Veri)	Hiçbir yere yazılmaz	**0 Saniye**	Parser düzeyinde Dropped
Konu Etiketleri	#yapayzeka, #teknoloji vb.	Frekans sıralaması	Web Worker Ring Buffer	**Azami 60 Dk**	Kayan pencere kova rotasyonu
Dil Dağılımı	ISO-639 kodları (tr, en, de)	Dil filtreleme analizi	Bellek içi Sayaç Map	**Azami 60 Dk**	Zaman aşımıyla bellek budama
Akış Hızı (PPM)	Sayısal dakika serisi	Yoğunluk grafiği	İstemci UI State	**5 - 60 Dk**	Pencere rotasyonu / Yenileme
Cloudflare KV Özet	Toplu JSON ({topHashtags})	Edge önbellekleme	Cloudflare KV Store	**3600 Saniye**	Otomatik expirationTtl imhası
Erişim Logları	IP (maskeli), HTTP status	Sistem güvenliği izleme	Vercel / Cloudflare Log	**7 Gün**	Platform log rotasyonu

3.2. Otomasyonlu Gizlilik Testi ve Bellek Taraması Kanıtı

Gizlilik güvencesi yalnızca kod incelemesiyle bırakılmamış; `next-app/scripts/test-privacy-minimization.mjs` komut dosyası ile otomatik regresyon testi olarak kurgulanmıştır. Test senaryosunda sentetik PII fikstürü kullanılarak negatif testler yürütülmüştür.

```
> next-app@0.1.0 test:privacy (node scripts/test-privacy-minimization.mjs)
--------------------------------------------------------------------------------
[G  ¤Á0L  ² DU5A0 1] Sentetik PII Fikstürü Üretildi: did:plc:synthetic_user_9999_secret_identifier
  Sentetik Veri: Telefon: 0555-019-9988 | Adres: Ataturk Cad. No:192 Manisa | PDS: synthetic-pds.com
[G  ¤Á0L  ² DU5A0 2] Agregator bellek dökümü (Heap Dump) JSON olarak tarand
  [PASS] Bellekte sentetik DID (did:plc:synthetic_user_9999) BULUNAMADI (0 match).
  [PASS] Bellekte telefon, adres veya hassas metin BULUNAMADI (0 match).
  [PASS] Bellekte PDS sunucu adresi BULUNAMADI (0 match).
[G  ¤Á0L  ² DU5A0 3]   7FVÖ6––R 7VçVÆ â 6æ  6†÷B _emas   FVæWFÆVæF“¢ F÷F ÄWfVçG2Â   ÒÂ F÷ † 6‡F w2Â Æ æw2 ƒ   ”’’à
[G  ¤Á0L  ² DU5A0 4] 5dk ve 60dk kayan pencere zaman a ñ1m   fR &VÆÆV² 'VF Ö  „Wf–7F–öâ’ Fñ ruland  à
[G  ¤Á0L  ² DU5A0 5] Konsol ve telemetri loglar  æF   ”’   & ÖWG&W6’ v^v–ÆÖVF‘ i do ÷'VÆ æA1.
================================================================================
[SONUÇ] TÜM G  ¤Á0L  ² dR dU!0 M  á0M  ¤ 5”ôåR DU5DÄU!0 BA ä $•”Ä  t\uA0 (5/5 PASS)!
```

3.3. Dürüst Artık Risk Analizi (Residual Risks)

• Hashtag Injection Riski: Kötü niyetli bir kullanıcının kimlik veya telefon numarasını doğrudan etiket olarak göndermesi (#05550199988). Sistem yalnızca en popüler ilk 10 etiketi genel trend olarak listelediğinden tekil sızıntılar eşiği aşamaz ve genel panoda görünmez.
• Trafik Analizi Riski: Bluesky ağındaki küresel yüksek hacim (+150 gönderi/sn) tekil kullanıcı sinyallerini bütünüyle maskelemektedir.

4. STRIDE TEHDİT MODELİ VE RİSK MATRİSİ

Sistem bileşenleri Microsoft STRIDE metodolojisi (Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege) çerçevesinde 10 temel tehdit senaryosu üzerinden kapsamlı şekilde incelenmiştir. Risk Skoru = Olasılık (1-5) × Etki (1-5) formülüyle hesaplanmıştır (Azami 25).

4.1. STRIDE Tehdit ve Risk Değerlendirme Tablosu (10 Tehdit)

No / Kat.	Tehdit Tanımı ve Senaryosu	O x E = Skor	Uygulanan Güvenlik Önlemi (Mitigation)	Artık Risk (Residual)
T01 (S)	Sahte Jetstream WS sunucusu taklidi (Spoofing)	**2 x 4 = 8 (Orta)**	WSS / TLS 1.3 zorunluluğu, CSP connect-src katı domain kilidi	CA ele geçirilmesi (Düşük)
T02 (T)	Akıştaki JSON paketlerinin yolda değiştirilmesi (MITM)	**2 x 3 = 6 (Düşük)**	TLS şifrelemesi ve Web Worker içi JSON şema denetimi	İstemci yerel zararlısı
T03 (T)	XSS ile zararlı JavaScript betiği enjeksiyonu	**2 x 5 = 10 (Orta)**	Katı CSP (script-src self), X-Content-Type-Options: nosniff	App Router inline istisnası
T04 (R)	Yönetici veya ziyaretçi işlemlerinin inkar edilmesi	**2 x 3 = 6 (Düşük)**	Postgres islem_kayitlari tablosunda değiştirilemez IP/Zaman logu	DB süper kullanıcı yetkisi
T05 (I)	Ham akıştan kişisel veri (DID/Metin) sızması [ATANAN]	**4 x 5 = 20 (Kritik)**	Sıfır Kalıcılık Güvenlik Duvarı, anlık imha, 3600s KV TTL, test paketi	Hashtag içine PII gizleme
T06 (I)	Hassas API anahtarı veya DB şifresinin sızması	**3 x 5 = 15 (Yüksek)**	gitleaks.toml sürekli tarama, Vercel Secret Store, PoLP CI	Geliştirici hatası (Runbook hazır)
T07 (I)	Kullanıcıların çerezler veya parmak iziyle izlenmesi	**2 x 3 = 6 (Düşük)**	Permissions-Policy (browsing-topics=(), geolocation=()), 0 çerez	ISS düzeyinde trafik analizi
T08 (D)	Jetstream akış patlamasıyla belleği şişirme (OOM)	**3 x 4 = 12 (Yüksek)**	Web Worker izolasyonu, 30/60 kovalı sınırlandırılmış ring-buffer	Aşırı CPU tüketimi
T09 (D)	Portföy ve API sayfalarına HTTP DDoS saldırısı	**3 x 3 = 9 (Orta)**	Cloudflare Rate Limiting (100 req/dk) ve Vercel Global Anycast CDN	Devasa botnet taşkını
T10 (E)	CI/CD iş akışına sızan paketin yetki yükseltmesi	**2 x 5 = 10 (Orta)**	GitHub Actions contents: read en az yetkisi, npm audit doğrulaması	GitHub altyapı açıkları

4.2. Özel Atanan Gizlilik Tehdidi (T05) Derinlemesine İncelemesi

T05 Tehdidi, ödev şartnamesinde özel olarak atanan en kritik saldırı yüzeyidir. Bluesky Jetstream üzerinde paylaşılan gönderiler her ne kadar kamuya açık olsa da, kullanıcıların telefon numaraları, T.C. kimlik numaraları, ev adresleri veya siyasi tercihleri gibi özel nitelikli kişisel verileri içerebilir. Sistemin bu verileri saklaması, işlemesi veya loglara yazması ağır hukuki yaptırımlar doğurur.

Savunma Mimarisi (Defense-in-Depth): (1) Veri İzolasyonu: WebSocket dinleyicisi `record.text` verisini hiçbir zaman kalıcı nesneye yazmaz. (2) Süzme: Yalnızca regex süzgeciyle `#` ile başlayan kelimeler ayrıştırılır. (3) Anonim Sayaçlaştırma: Belleğe sadece frekans haritası aktarılır. (4) Test Güvencesi: `test-privacy-minimization.mjs` test komutu ile sistemin belleğinde DID veya metin kalmadığı otomatik olarak kanıtlanır.

5. EN AZ YETKİ, GİZLİ ANAHTAR VE CI/CD GÜVENLİĞİ

Sistemde kullanılan tüm servis kimlikleri ve otomasyon süreçleri En Az Yetki Prensibi (Principle of Least Privilege - PoLP) doğrultusunda yapılandırılmıştır. Hiçbir servis, işlevini yerine getirmek için gereken asgari kapsamın ötesinde yetkiye sahip değildir.

5.1. Servis ve Kimlik Yetki Matrisi (Least-Privilege Matrix)

Kimlik / Servis Hesabı	Platform / Ortam	Atanan İzinler / Kapsamlar	Teknik Gerekçe & Kısıtlanan Yetkiler
GitHub Actions CI Botu	GitHub Workflows	**contents: read, security-events: write**	Yalnızca kod okuma ve SARIF yükleme. Koda yazma (write) engelli.
Cloudflare Worker	Cloudflare Workers/KV	**KV:Read, KV:Write (PULSE_KV)**	1 saatlik önbellek sunma ve 3600s TTL. DNS/hesap yönetimi yok.
Vercel Deploy Servisi	Vercel Deployment	**Deployments:Create, Project:Read**	Next.js kenar dağıtımı. Takım ve faturalandırma yönetimi kapalı.
Neon Postgres İstemcisi	Neon Serverless	**SELECT, INSERT (islem, iletisim)**	Portföy iletişim ve video sayaçları. Canlı akış bağlanmaz.
Jetstream WS İstemcisi	Bluesky Relay API	**Salt-okunur WS (app.bsky.post)**	Genel akışı anonim tüketme. Kimlik veya yazma yetkisi yoktur.
AWS Bütçe Denetleyicisi	AWS Budgets & SNS	**budgets:View/Modify, sns:Publish**	Aylık 0 TL / 0.01 USD alarmı tetikleme. EC2/S3/IAM yetkisi yok.

5.2. Gizli Anahtar ve Bağımlılık Güvenlik Taramaları

• Gitleaks Gizli Anahtar Denetimi: `.gitleaks.toml` kural dosyası ile Neon veritabanı URL'leri, Cloudflare belirteçleri ve özel şifre desenleri sürekli taranmaktadır. İstemci paketinde (Next.js client bundle) hiçbir API anahtarı yer almaz; hassas anahtarlar platform ortam değişkenlerinde tutulur.
• Bağımlılık Taraması (npm audit): `next-app` projesinde yer alan 511 bağımlılık paketinin güvenlik taraması yapılmış ve 0 güvenlik açığı (0 Low, 0 Moderate, 0 High, 0 Critical) tespit edilmiştir. `.github/dependabot.yml` ile haftalık otomatik tarama aktiftir.

5.3. GitHub `main` Dalı Koruma Kuralları Rehberi (Branch Protection)

GitHub depolama ayarlarında doğrudan dal koruması repo sahibi yetkisi gerektirdiğinden, yapılması gereken resmi ayarlar `docs/security/branch-protection-guide.md` dosyasında belgelenmiştir: (1) Require pull request before merging (en az 1 onay), (2) Require status checks to pass (Gitleaks, npm audit, privacy tests, build check), (3) Require signed commits, (4) Block force pushes (`git push --force` engeli), (5) Do not allow deletions (`main` dalının silinmesini engelleme).

6. WEB GÜVENLİĞİ VE OWASP ZAP DENETİMİ

Canlı üretim sitesi (`https://metehan-gezer.vercel.app`) ve yerel geliştirme ortamı üzerinde HTTP güvenlik başlıkları ile OWASP ZAP Pasif/Baseline güvenlik denetimleri gerçekleştirilmiştir.

6.1. HTTP Güvenlik Başlıkları: Öncesi ve Sonrası (Before / After)

Güvenlik Başlığı	Önceki Durum (Before)	Sertleştirilmiş Durum (After)	Teknik Güvenlik Etkisi
Strict-Transport-Security	max-age=63072000	**max-age=63072000; preload**	2 yıl HTTPS zorunluluğu, HSTS Preload tam uyumu.
X-Content-Type-Options	Eksik (Mevcut değil)	**nosniff**	MIME sniffing ve script enjeksiyonunu engeller.
X-Frame-Options	Eksik (Mevcut değil)	**SAMEORIGIN**	Harici iframe içine alma ve Clickjacking'i önler.
Referrer-Policy	Eksik (Mevcut değil)	**strict-origin-when-cross-origin**	Dış kaynaklara hassas URL yolu sızıntısını engeller.
Permissions-Policy	Eksik (Mevcut değil)	**camera=(), microphone=()...**	Kamera, mikrofon, konum API'lerini devre dışı bırakır.
Content-Security-Policy	Eksik (Mevcut değil)	**Katı İlke (self, wss, youtube)**	XSS ve yetkisiz veri sızdırmayı engeller.
security.txt (RFC 9116)	Eksik (404 Not Found)	**/.well-known/security.txt (200)**	Araştırmacılar için sorumlu bildirim kanalı sağlar.

6.2. İçerik Güvenlik Politikası (CSP) ve Teknik İstisna Gerekçeleri

• 'unsafe-inline' / 'unsafe-eval': Next.js App Router istemci tarafı dinamik hidrasyonu (React Server Components) için teknik zorunluluktur.
• wss://jetstream1.us-east.bsky.network: Canlı Bluesky Jetstream WebSocket akışına bağlanabilmek için zorunlu veri kaynağıdır.
• https://www.youtube-nocookie.com: Vaka analizi sayfasındaki doğrulanmış demo videosunun (3Xz3kawRV9M) gizlilik odaklı gömülmesi içindir.

6.3. OWASP ZAP Pasif/Baseline Tarama Bulguları Tablosu

ZAP Uyarı Adı & Kodu	Risk Seviyesi	İlk Tarama (Initial)	Uygulanan Düzeltme (Fix)	Sonuç
10038 - CSP Header Not Set	**Orta (Medium)**	CSP başlığı yanıtta yoktu.	next.config.ts ve vercel.json katı CSP	**ÇÖZÜLDÜ (PASS)**
10021 - X-Content-Type-Options	**Düşük (Low)**	Başlık eksikti.	X-Content-Type-Options: nosniff eklendi	**ÇÖZÜLDÜ (PASS)**
10020 - Anti-clickjacking Header	**Orta (Medium)**	X-Frame-Options yoktu.	SAMEORIGIN ve frame-ancestors eklendi	**ÇÖZÜLDÜ (PASS)**
10063 - Permissions-Policy Header Not Set	**Düşük (Low)**	Politika tanımlı değildi.	Permissions-Policy başlığı eklendi	**ÇÖZÜLDÜ (PASS)**
10035 - Strict-Transport-Security	**Düşük (Low)**	Preload bayrağı eksikti.	includeSubDomains; preload parametresi	**ÇÖZÜLDÜ (PASS)**

7. İZLEME, MALİYET VE OLAY MÜDAHALE

Bulut operasyonlarının sürdürülebilirliği, beklenmeyen maliyetlerin önlenmesi ve güvenlik ihlallerine anında müdahale için merkezi telemetri ve 7 aşamalı Olay Müdahale Kılavuzu (Incident Response Runbook) kurgulanmıştır.

7.1. 0 TL Maliyet ve Bütçe Kontrolü (AWS Budgets & Cloudflare Watchdog)

Tüm mimari ücretsiz katmanlar (Free Tier) sınırları içinde kalacak şekilde optimize edilmiştir: Vercel (100 GB bant genişliği / 0 TL), Cloudflare Workers (günlük 100 bin istek / 0 TL), Cloudflare KV (günlük 100 bin okuma / 0 TL), Neon Postgres (0.5 GB / 0 TL). Terraform ile tanımlanan `aws_budgets_budget.zero_cost_watchdog` kuralı, harcama 0.01 USD seviyesine ulaştığı anda `gztmetehan@gmail.com` adresine acil e-posta alarmı tetikler. 30 Ekim 2026 itibarıyla cari fatura tutarı tam olarak 0.00 TRY / 0.00 USD'dir.

7.2. Tek Sayfalık Olay Müdahale Kılavuzu (IR-RUNBOOK-01: Sızan API Anahtarı)

AŞAMA 1: TESPİT (Detect & Triage)
Gitleaks CI uyarısı, GitHub Secret Scanning bildirimi veya security.txt üzerinden araştırmacı ihbarı alınır. Sızan anahtarın türü (Neon DB, Cloudflare Token) ve commit karma kodu anında belirlenir.

AŞAMA 2: İPTAL (Revoke < 15 Dk)
Kod düzeltmesi beklenmeksizin konsoldan ilgili belirteç iptal edilir: Neon Console > Reset Password veya Cloudflare Dashboard > API Tokens > Revoke.

AŞAMA 3: ROTASYON (Rotate)
En az yetkili yeni belirteç üretilir. Yeni anahtar koda veya yerel bilgisayara yazılmadan doğrudan Vercel / GitHub Secrets kasasına güvenli olarak girilir ve redeploy yapılır.

AŞAMA 4: ADLİ İNCELEME (Investigate)
Sızıntı anı ile iptal anı arasındaki zaman penceresi belirlenir. Neon Postgres query logları ve Vercel erişim logları taranarak yabancı IP adreslerinden yetkisiz sorgu gelip gelmediği incelenir.

AŞAMA 5: ETKİ DEĞERLENDİRMESİ (Assess)
Canlı sosyal medya akışı veri saklamadığından (zero-retention) bu taraftan kişisel veri sızıntısı imkansızdır. BVA 2205 iletişim tablosunun okunup okunmadığı doğrulanır.

AŞAMA 6: BİLDİRİM (Notify)
İletişim mesajlarında gerçek isim/e-posta sızıntısı tespit edilirse 72 saat içinde KVKK'ya resmi bildirim yapılır. Sadece anonim sayaç anahtarı sızdıysa KVKK bildirimi gerekmez.

AŞAMA 7: İYİLEŞTİRME (Recovery)
Geçmiş commit'ler git-filter-repo ile temizlenir, kök neden analizi yapılır, GitHub Push Protection kuralları zorunlu hale getirilir.

7.3. Akademik Sonuç ve Doğrulama Beyanı

Bu raporda yer alan tüm ölçümler, test çıktıları, güvenlik başlıkları ve mimari şemalar öğrenci Metehan Gezer tarafından bizzat geliştirilmiş, test edilmiş ve belgelenmiştir. Gerçek zamanlı büyük veri akışlarında "Sıfır Kalıcılık" mimarisiyle kişisel veri sızıntılarının bütünüyle önlenebileceği, katı güvenlik başlıkları ve en az yetki prensipleriyle modern bir veri ürününün 0 TL maliyetle yüksek güvenlik standartlarında yayınlanabileceği somut kanıtlarla doğrulanmıştır.

Raporu Hazırlayan: Metehan Gezer (2516016026) | **İmza / Onay:** Metehan Gezer | **Tarih:** 30 Ekim 2026

Manisa Celal Bayar Üniversitesi — Disiplinlerarası Büyük Veri Analistliği Lisansüstü Programı